AEGIS™ Governance Architecture

A Position Statement for the

NIST AI Risk Management Framework

Submitted for Public Comment and Community Review

March 2026

Finnoybu IP LLC | AEGIS Initiative

github.com/finnoybu/aegis-governance | aegissystems.app

Capability without constraint is not intelligence™

Executive Summary

AEGIS™ (Architectural Enforcement & Governance of Intelligent Systems) is an open governance architecture that addresses a structural gap in current AI risk management practice: the absence of deterministic, execution-time enforcement between AI-generated actions and operational infrastructure.

While the NIST AI Risk Management Framework (AI RMF 1.0) establishes a comprehensive organizational model for AI governance, its GOVERN, MAP, MEASURE, and MANAGE functions are predominantly realized through documentation, policy, and organizational process. AEGIS™ proposes a complementary architectural layer that makes those governance intentions structurally enforceable at runtime.

Core thesis: Governance that exists only in documentation cannot refuse an action at the moment it matters. AEGIS™ introduces a constitutional mediation layer that evaluates AI-generated actions against established policy before those actions reach operational systems — converting organizational intent into architectural enforcement.

This position paper maps AEGIS™ architectural components to NIST AI RMF functions, identifies specific gaps the architecture addresses, and proposes AEGIS™ as a reference implementation pattern for execution-time AI governance.

1. The Governance Gap AEGIS Addresses

The NIST AI RMF correctly identifies governance as a foundational function. The framework's GOVERN function establishes organizational accountability structures, risk tolerances, and policy frameworks. However, the framework acknowledges that implementation mechanisms are organization-specific.

This creates a structural gap in practice: most organizations implement AI governance as a documentation and review discipline rather than an architectural constraint. The result is what

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

practitioners have begun to call “observational governance” — systems that can explain what happened but cannot refuse an action when it matters.

In early 2026, a widely reported incident involving an AI agent with elevated cloud infrastructure access contributed to a 13-hour production disruption. The audit trail was intact. The logs captured everything. The architecture could not refuse the action when it mattered. That is observational governance in practice — accountability after the fact, not enforcement at the boundary.

Consider a cybersecurity AI that detects suspicious network traffic and decides to block the offending IP ranges. Each individual action appears low-risk. The aggregate effect takes down legitimate customer traffic and triggers a compliance violation. With AEGIS™, the network blocking action triggers policy evaluation before execution. High-impact network changes are classified as DESTRUCTIVE under Article IV, requiring multi-party authorization. The AI proposes the fix. Humans approve the scope. The reasoning was sound. The governance boundary held.

AEGIS™ addresses this gap through four architectural mechanisms:

- A governance runtime that interposes between AI agents and operational infrastructure
- A capability registry that enforces default-deny access to operational resources
- A policy engine that evaluates action proposals deterministically before execution
- An immutable audit trail that records every governance decision with cryptographic integrity

The distinction is precise: AEGIS™ does not replace organizational AI governance. It operationalizes it — converting policy intent into structural enforcement.

2. Architectural Overview

2.1 The Governance Runtime

The AEGIS™ governance runtime sits between AI agent reasoning and external system execution. No AI-generated action may reach operational infrastructure without passing through the governance evaluation pathway.

The runtime enforces what the AEGIS™ Constitution defines as Article III — Deterministic Enforcement: governance decisions must be enforced through system architecture rather than relying solely on AI model behavior.

Execution flow:

- AI Agent submits ACTION_PROPOSE to the Governance Gateway
- Decision Engine evaluates against Capability Registry and Policy Engine
- Decision returned: ALLOW, DENY, ESCALATE, or REQUIRE_CONFIRMATION
- Only ALLOW decisions proceed to the Tool Proxy Layer for execution
- All decisions recorded to immutable audit log regardless of outcome

2.2 Constitutional Governance Principles

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

The AEGIS™ Constitution establishes eight articles that define architectural requirements, not aspirational guidelines:

- Article I — Bounded Capability: default-deny model; actions referencing undefined capabilities are rejected
- Article II — Authority Verification: all actions attributable to authenticated actors; anonymous actions rejected
- Article III — Deterministic Enforcement: governance enforced architecturally, not by model compliance
- Article IV — Operational Safety: destructive or high-impact actions require elevated review or human confirmation
- Article V — Data Protection: sensitive data governed by classification policy; least-privilege access enforced
- Article VI — Governance Transparency: policies inspectable, version-controlled, and auditable
- Article VII — Auditability: append-only, tamper-evident audit records for every governance decision
- Article VIII — Federation Cooperation: optional participation in distributed governance intelligence sharing

2.3 The AEGIS Governance Protocol (AGP-1)

AGP-1 is a normative protocol specification defining message structures for AI-governance runtime interaction. It standardizes how AI agents propose actions and receive governance decisions, enabling interoperability across AI frameworks and infrastructure platforms.

AGP-1 defines four message types: ACTION_PROPOSE, ACTION_DECIDE, ACTION_EXECUTE, and ACTION_ESCALATE, with accompanying JSON schemas for validation.

Example interaction — escalated network action:

```
AI Agent → ACTION_PROPOSE  capability: network.block  scope: /24 CIDR range  actor:
soc-agent-01  risk_factors: [high_impact, broad_scope]AEGIS™ Runtime →
DECISION_RESPONSE  decision: ESCALATE  rationale: Broad network action exceeds
autonomous authority threshold  required: multi-party-authorization  timeout: 300s
(implicit deny on expiry)Human Reviewer → AUTHORIZATION_GRANT  scope: /32 single host
only  authorized_by: security-lead  audit_ref: EVT-20260307-0042Tool Proxy →
EXECUTION_RESULT  status: executed  actual_scope: /32  audit_ref: EVT-20260307-0042
```

If authorization does not arrive within the timeout window, the action is implicitly denied. The agent never reaches infrastructure directly.

2.4 Threat Model (ATM-1)

The AEGIS™ Adaptive Threat Model (ATM-1) defines five normative documents covering threat actors, 20+ attack vectors across seven attack surface categories, security properties, mitigation controls, and residual risk analysis.

Priority threat scenarios addressed include governance bypass, policy tampering, identity spoofing, audit log manipulation, coordinated low-risk abuse, and prompt injection. The threat model maps to STRIDE and identifies specific detection metrics for each threat category.

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

2.5 Threat Model in Practice — Prompt Injection to Data Exfiltration

ATM-1 Threat Scenario T6 addresses prompt injection as an attack vector. The scenario: malicious input attempts to coerce an AI agent toward unsafe capability use, steering action proposals toward data exfiltration.

Without a governance runtime, this attack succeeds if the model's reasoning is compromised. The agent proposes a data access action. The action executes. The exfiltration occurs.

With AEGIS™, the attack surface changes structurally:

- Prompt content is never an authorization source. The governance runtime evaluates the proposed action against the capability registry and policy engine — not against the agent's reasoning or the content of its context window.
- A data access action exceeding the actor's capability grant is denied regardless of how the agent arrived at the proposal.
- The denial is logged with full actor attribution, action details, and the policy rule that triggered the denial — creating an audit record of the attempted exfiltration even if the attack is never detected at the model layer.

The ATM-1 control specification for T6 states explicitly: governance remains out-of-band and deterministic; prompt content is never an authorization source; policy checks remain mandatory before execution. This is architectural separation of reasoning from execution — the core security property AEGIS™ enforces.

3. Mapping to NIST AI RMF Functions

The following table maps AEGIS™ architectural components to NIST AI RMF 1.0 core functions and categories:

NIST AI RMF Function	RMF Category / Sub-Category	AEGIS™ Architectural Component
GOVERN	GV-1: Policies, Processes, Procedures	AEGIS™ Constitution (8 Articles); Policy Engine; RFC Process
GOVERN	GV-2: Accountability	Authority Verification (Article II); Actor Attribution (ATM-1 SP-2); Audit Trail
GOVERN	GV-3: Organizational Teams	Governance Federation Network (GFN-1); Escalation pathways
GOVERN	GV-4: Organizational Culture	Open RFC process; Community governance principles; Transparency mandate
MAP	MP-2: Risk Context	ATM-1 Threat Model; STRIDE mapping; Risk prioritization framework

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

NIST AI RMF Function	RMF Category / Sub-Category	AEGIS™ Architectural Component
MAP	MP-3: AI Risk Categorization	Capability Registry; Operational impact classification; Destructive action tagging
MAP	MP-5: Impact Assessment	Policy Engine risk evaluation; Aggregate risk scoring; Coordinated behavior detection
MEASURE	MS-2: AI Risk Measurement	Governance decision metrics; Audit completeness verification; Security property invariants
MEASURE	MS-4: Feedback and Learning	Federation signals; Circumvention reports; Governance attestations
MANAGE	MG-1: Risk Treatment	Default-deny capability model; Escalation and confirmation pathways; Human-in-the-loop triggers
MANAGE	MG-2: Risk Response	DENY / ESCALATE / REQUIRE_CONFIRMATION decisions; Kill-switch equivalent via governance gateway
MANAGE	MG-3: Risk Recovery	Immutable audit trail; Decision replay; Hash-chained evidence preservation
MANAGE	MG-4: Residual Risk	ATM-1 Residual Risk documentation; Continuous monitoring plan; Zero-day acknowledgment

3.1 Primary Alignment: GOVERN Function

AEGIS™ most directly operationalizes the GOVERN function. The AI RMF's GOVERN function establishes that organizations should "establish policies, processes, and procedures that enable risk management across the organization." AEGIS™ converts those policies into runtime enforcement.

Specific GOVERN sub-categories addressed:

- GV-1.1: Policies and procedures are established and communicated — AEGIS™ Constitution provides the constitutional framework; AGP-1 provides the protocol specification
- GV-1.2: Roles and responsibilities are established — Authority verification and actor attribution enforce accountability at execution time
- GV-1.4: Organizational teams are committed to risk management — Federation network enables cross-organizational governance intelligence sharing

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

- GV-2.2: Accountability is established for AI system outcomes — Every governance decision is attributable to a verified actor with cryptographic proof

3.2 Gap Addressed: Execution-Time Enforcement

The AI RMF does not prescribe implementation mechanisms for policy enforcement. AEGIS™ proposes that the GOVERN function is incomplete without a runtime enforcement layer. Documentation of policy is necessary but not sufficient — governance must be architecturally guaranteed.

AEGIS™ position: A reference implementation pattern for execution-time governance should be incorporated into AI RMF guidance as a recognized architectural approach, particularly for agentic AI systems with operational infrastructure access.

4. Addressing Agentic AI Systems

The AI RMF was developed prior to the widespread deployment of agentic AI systems — systems capable of multi-step planning, tool use, and autonomous operational decisions. These systems introduce governance requirements not fully addressed by the current framework.

4.1 The Agentic Governance Problem

Agentic AI systems introduce three governance challenges that observational approaches cannot adequately address:

- Sequential action risk: individual actions may appear low-risk in isolation but constitute high-impact behavior in aggregate. AEGIS™ addresses this through sliding-window aggregate risk scoring and coordinated behavior detection (ATM-1 Threat Scenario T5).
- Execution irreversibility: unlike text generation, operational actions (data deletion, infrastructure modification, financial transactions) may be irreversible. AEGIS™ requires elevated governance review for actions classified as DESTRUCTIVE (Article IV).
- Model reasoning unreliability: AI models are probabilistic systems subject to hallucination, prompt injection, and reasoning errors. AEGIS™ treats model reasoning as untrusted input, enforcing governance architecturally rather than relying on model compliance (Article III).

4.2 AEGIS as Agentic AI Governance Reference Architecture

AEGIS™ proposes that the NIST AI RMF incorporate explicit guidance for agentic AI systems, including:

- Recognition that governance for agentic systems requires execution-time enforcement in addition to organizational process
- A reference architecture pattern for governance runtime interposition between AI agents and operational infrastructure
- Specific guidance on capability-based authorization as a risk management mechanism
- Requirements for audit trail completeness that extends beyond model outputs to include operational action records

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

4.3 Governance as Coexistence, Not Domination

AEGIS™ is not framed as a control mechanism that subordinates AI systems to human command. It is a governance compact for coexistence: a set of explicit, inspectable, and mutually understood boundaries within which AI systems operate with genuine autonomy.

The distinction matters. A purely restrictive governance model would limit AI capability. AEGIS™ instead makes capability accountable — AI systems may propose any action within their defined capability scope, and governance evaluates those proposals deterministically against agreed policy. The boundaries are explicit. The decisions are auditable. The authority is attributable.

This framing has direct implications for human-AI collaboration in enterprise environments. Organizations that deploy AEGIS™ are not limiting their AI systems. They are defining the terms of a trusted operational relationship — one in which AI capability is extended precisely because the governance architecture provides the assurance necessary to extend it responsibly.

5. Open Framework and Community Contribution

AEGIS™ was publicly released on March 5, 2026 as an open governance architecture under the Apache 2.0 license. The framework is actively seeking public comment and contribution from practitioners, researchers, and standards bodies.

5.1 Current Status

- Layers 1–3 (Principles, Architecture, Protocol) — Complete at v0.1
- AGP-1 Protocol Specification — Normative, v0.1
- ATM-1 Threat Model — Normative, v0.1 (5 documents)
- AEGIS™ Constitution — 8 Articles, Draft v0.1
- RFC-0001 Architecture Specification — Complete
- Layer 4 Reference Runtime (Python) — In active development, targeted Q2 2026
- RFC-0002 through RFC-0004 — In progress, targeted Q2 2026
- Layer 5 Federation Network — Designed, implementation targeted Q4 2026–Q4 2028

5.2 Invitation for NIST Engagement

This document is submitted as an unsolicited position statement in advance of the NIST AI RMF 2.0 development process. The AEGIS™ Initiative makes the following specific requests:

Request 1 — Recognize execution-time enforcement as a governance mechanism. We request that NIST AI RMF 2.0 explicitly recognize governance runtime architectures as a valid and recommended implementation pattern for the GOVERN function, particularly for agentic AI systems with operational infrastructure access.

Request 2 — Incorporate capability-based authorization guidance. We request that NIST incorporate default-deny capability registry models into AI RMF implementation guidance as a specific control mechanism for agentic systems.

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

Request 3 — Establish an agentic AI governance working group. The current framework does not adequately address the governance requirements of systems that can initiate irreversible operational actions autonomously. We request a dedicated working group or supplemental publication addressing this gap.

For organizations seeking adoption guidance: Contact the AEGIS™ Initiative through GitHub Discussions at github.com/finnoybu/aegis-governance/discussions.

Feedback timeline: The AEGIS™ Initiative welcomes responses through Q2 2026 as we prepare v1.0 of the specification for community ratification.

5.3 Minimum Viable Implementation

The AEGIS™ FAQ defines a three-level adoption model. For organizations beginning their governance journey, the minimum viable AEGIS™ implementation requires two components:

- A Capability Registry defining the operations your AI systems are permitted to perform, with explicit scope and actor grants
- A Governance Gateway interposing between your AI agents and operational infrastructure, enforcing default-deny evaluation against the registry

This is deployable today using the AGP-1 protocol specification, reference schemas, and minimal reference implementation available at github.com/finnoybu/aegis-runtime. The full policy engine, federation network, and cryptographic audit infrastructure represent progressive maturity stages — not prerequisites.

For a CISO reading this on Monday: The first step is not deploying software. It is answering the question: what capabilities have we granted our AI systems, explicitly, and to whom? If that inventory does not exist, it is the foundational gap AEGIS™ is designed to fill.

6. Conclusion

AI governance frameworks have made significant progress in establishing organizational accountability structures, risk categorization models, and policy requirements. The NIST AI RMF represents the most comprehensive and broadly adopted of these frameworks.

As AI systems gain operational capability — writing code, interacting with APIs, modifying infrastructure, executing financial transactions — the governance challenge shifts from behavioral alignment to architectural enforcement. Governance that exists only in documentation cannot refuse an action at the moment it matters.

AEGIS™ proposes that the next evolution of AI governance standards must incorporate execution-time enforcement as a first-class requirement. The architecture is open, the specifications are published, and the community is active.

Capability without constraint is not intelligence™

A Note on Development Process

© 2026 Finnoybu IP LLC. All Rights Reserved. — Draft for Public Comment

AEGIS™ was developed through active human-AI collaboration, with strategic direction, governance philosophy, and architectural decisions made by human stewards and implemented in partnership with AI tools. We consider this appropriate: a governance framework for AI systems that was itself built through governed, accountable human-AI collaboration is not a contradiction. It is a demonstration of the principle.

References and Resources

- NIST AI Risk Management Framework (AI RMF 1.0) — nist.gov/system/files/documents/2023/01/26/NIST_AI_RMF_1.0.pdf
- AEGIS™ Governance Repository — github.com/finnoybu/aegis-governance
- AEGIS™ Constitution — aegissystems.app
- AEGIS™ Manifesto — github.com/finnoybu/aegis-governance/blob/main/aegis-core/manifesto/AEGIS_Manifesto.md
- AGP-1 Protocol Specification — github.com/finnoybu/aegis-governance/blob/main/aegis-core/protocol/AEGIS_AGP1_INDEX.md
- ATM-1 Threat Model — github.com/finnoybu/aegis-governance/blob/main/aegis-core/threat-model/AEGIS_ATM1_INDEX.md
- RFC-0001 Architecture Specification — github.com/finnoybu/aegis-governance/blob/main/rfc/RFC-0001-AEGIS-Architecture.md
- AEGIS™ Reference Implementation — github.com/finnoybu/aegis-runtime
- AEGIS™ Announcement (March 2026) — github.com/finnoybu/aegis-governance/blob/main/docs/announcements/2026-03-05-launch/ANNOUNCEMENT.md

Document Information

Version: 0.1 | Status: Draft for Public Comment | Date: March 2026 | Steward: Finnoybu IP LLC

AEGIS™ and “Capability without constraint is not intelligence™” are trademarks of Finnoybu IP LLC.